

Практическое занятие № 2

Тема: Классификация сетевых атак и их признаков

Продолжительность: 2 академических часа

Формат: практическая работа с аналитическими таблицами и элементами моделирования IDS-логики

Связь с лекционным курсом: соответствует лекции 2 «Современные компьютерные атаки как объект обнаружения»

1. Цель практического занятия

Сформировать у студентов практические навыки классификации сетевых атак, определения их наблюдаемых признаков в сетевом трафике и журналах событий, а также подготовки первичной аналитической базы для последующего построения IDS-моделей с использованием искусственного интеллекта.

2. Задачи практического занятия

В ходе выполнения работы студент должен научиться:

1. Классифицировать основные виды сетевых атак.
2. Определять технические признаки атак в трафике и логах.
3. Связывать тип атаки с источниками данных для обнаружения.
4. Формировать таблицу признаков атак.
5. Отличать сетевые, прикладные, учетные и поведенческие признаки.
6. Формулировать простые правила обнаружения атак.
7. Подготавливать признаки, которые в дальнейшем могут быть использованы в ML-модели IDS.

3. Формируемые компетенции

В результате выполнения практической работы студент должен:

Знать:

1. основные типы сетевых атак;
2. признаки атак в трафике и журналах событий;
3. источники данных для IDS;
4. различие между сигнатурным и поведенческим признаком атаки;
5. роль признаков атак в машинном обучении.

Уметь:

1. анализировать описание инцидента;
2. выделять признаки атаки;
3. определять возможный тип атаки;
4. подбирать источники данных для обнаружения;
5. составлять таблицу «атака — признаки — источник данных»;
6. формулировать простые IDS-правила.

Владеть:

1. первичной методикой анализа сетевых атак;
2. навыком структурирования признаков для последующего анализа ИИ-моделью;
3. базовым языком описания событий безопасности.

4. Краткая теоретическая часть

4.1. Что такое сетевая атака

Сетевая атака — это преднамеренное воздействие на информационную систему, сетевую инфраструктуру, сервис, приложение или учетную запись, направленное на нарушение конфиденциальности, целостности или доступности информации.

Сетевая атака может быть направлена на:

1. сервер;
2. рабочую станцию;
3. сетевое оборудование;
4. веб-приложение;
5. базу данных;
6. учетную запись пользователя;
7. канал связи;
8. облачную инфраструктуру;
9. IoT-устройство.

4.2. Почему важно классифицировать атаки

Классификация атак нужна для того, чтобы:

1. понимать характер угрозы;
2. выбирать правильные источники данных;
3. настраивать IDS/IPS;
4. формировать признаки для ML-модели;
5. оценивать критичность события;
6. выбирать меры реагирования;
7. снижать количество ложных срабатываний.

Например, **DDoS-атака** проявляется как резкий рост сетевых запросов, а **brute force** — как множество неудачных попыток входа. Эти атаки имеют разные признаки и требуют разных источников данных.

4.3. Основные группы атак

В рамках данной практической работы будем использовать следующую классификацию.

Группа атак	Содержание	Примеры
Разведка и сканирование	поиск активных узлов, портов, сервисов	port scanning, ping sweep
Атаки на учетные записи	подбор или использование учетных данных	brute force, credential stuffing
Атаки на доступность	перегрузка сервиса или сети	DoS, DDoS
Атаки на веб-приложения	эксплуатация уязвимостей веб-сервисов	SQL injection, XSS, path traversal
Вредоносная активность	действия malware или botnet	beaconing, C2-соединения
Боковое перемещение	распространение внутри сети	lateral movement

Вывод данных	несанкционированная передача информации	data exfiltration
Повышение привилегий	получение более высоких прав	privilege escalation

5. Исходные данные для выполнения работы

Студенту предлагается рассмотреть набор условных событий безопасности. На их основе необходимо определить возможные типы атак, признаки и источники данных.

Таблица 1. Условные события безопасности

№	Описание события
1	Один внешний IP-адрес за 30 секунд отправил TCP SYN-запросы на 80 разных портов одного сервера
2	За 5 минут зафиксировано 250 неудачных попыток входа по SSH для пользователя admin
3	Веб-сервер получил большое количество запросов с параметрами вида ' OR '1'='1
4	Рабочая станция пользователя каждые 60 секунд обращается к неизвестному внешнему домену
5	В течение 10 минут объем входящих HTTP-запросов к сайту вырос в 50 раз
6	Пользователь после входа в систему начал обращаться к серверам, с которыми ранее не взаимодействовал
7	На сервере базы данных ночью выполнен экспорт большой таблицы, после чего зафиксирована передача 2 ГБ данных во внешний адрес
8	Пользовательская учетная запись была добавлена в группу администраторов без заявки на изменение доступа
9	В логах веб-сервера обнаружены запросы вида <script>alert(1)</script>
10	Несколько рабочих станций одновременно начали устанавливать соединения с одним и тем же внешним IP-адресом

6. Основное задание

Задание 1. Классификация событий

Для каждого события из таблицы 1 необходимо определить вероятный тип атаки.

Заполнить таблицу.

№ события	Вероятный тип атаки	Краткое обоснование
1		
2		
3		
4		
5		
6		
7		
8		
9		
10		

Задание 2. Определение признаков атак

Для каждого типа атаки необходимо определить признаки, которые могут быть использованы IDS или ML-моделью.

Заполнить таблицу.

Тип атаки	Сетевые признаки	Признаки в логах	Поведенческие признаки
Port scanning			
Brute force			
SQL injection			
XSS			

DDoS			
Malware beaconing			
Lateral movement			
Data exfiltration			
Privilege escalation			

Задание 3. Определение источников данных

Необходимо определить, из каких источников IDS может получить данные для обнаружения каждой атаки.

Заполнить таблицу.

Тип атаки	Основные источники данных	Дополнительные источники
Port scanning		
Brute force		
SQL injection		
XSS		
DDoS		
Malware beaconing		
Lateral movement		
Data exfiltration		
Privilege escalation		

Примеры источников данных:

1. firewall logs;

2. NetFlow;
3. PCAP;
4. DNS logs;
5. proxy logs;
6. web server logs;
7. authentication logs;
8. Windows Event Log;
9. Linux auth.log;
10. Active Directory logs;
11. database audit logs;
12. EDR logs;
13. DLP logs;
14. SIEM;
15. IDS/IPS alerts.

Задание 4. Формирование простых правил обнаружения

Для пяти выбранных атак необходимо сформулировать простые правила обнаружения в человеко-читаемом виде.

Пример:

Если за 5 минут от одного IP-адреса зафиксировано более 50 неудачных попыток входа по SSH,
то сформировать событие "Возможный brute force".

Заполнить таблицу.

№	Тип атаки	Правило обнаружения
1		
2		
3		
4		
5		

Задание 5. Подготовка признаков для ML-модели IDS

Необходимо предложить признаки, которые можно использовать для обучения модели машинного обучения.

Заполнить таблицу.

Признак	Тип данных	Что показывает	Для каких атак полезен
connection_count	числовой	количество соединений за период	scanning, DDoS
failed_login_count	числовой	число ошибок входа	brute force
unique_dst_ports	числовой	число уникальных портов назначения	scanning
bytes_out	числовой	объем исходящего трафика	data exfiltration
dns_query_interval	числовой	интервал между DNS-запросами	beaconing

Студент должен добавить не менее **10 признаков**.

7. Пример выполнения фрагмента задания

Пример для события № 1

Событие:

Один внешний IP-адрес за 30 секунд отправил TCP SYN-запросы на 80 разных портов одного сервера.

Элемент анализа	Ответ
Вероятный тип атаки	Port scanning
Сетевой признак	большое количество SYN-запросов к разным портам
Признак в логах	множество попыток подключения к закрытым или разным портам
Источник данных	firewall logs, NetFlow, PCAP, IDS alerts
Простое правило	если один источник обращается более чем к 50 портам одного хоста за 1 минуту, сформировать тревогу

Возможные ML-признаки	unique_dst_ports, connection_count, syn_count, time_window, dst_host_count
-----------------------	--

Пример для события № 2

Событие:

За 5 минут зафиксировано 250 неудачных попыток входа по SSH для пользователя admin.

Элемент анализа	Ответ
Вероятный тип атаки	Brute force
Сетевой признак	частые подключения к порту 22
Признак в логах	много событий login_failed
Источник данных	Linux auth.log, SSH logs, SIEM, firewall logs
Простое правило	если за 5 минут число неудачных входов по SSH превышает 20, создать событие brute force
Возможные ML-признаки	failed_login_count, login_attempt_rate, unique_src_ip_count, success_after_fail, target_user

8. Индивидуальные варианты заданий

Преподаватель может распределить студентов по вариантам. Каждый студент выбирает один вариант и выполняет полный анализ.

Вариант 1. Разведка сети

В логах firewall обнаружено, что внешний IP-адрес последовательно обращался к портам 21, 22, 23, 25, 53, 80, 443, 445, 3389 на одном сервере. Большинство соединений завершились отказом.

Необходимо определить:

1. тип атаки;
2. признаки;
3. источники данных;
4. правило обнаружения;
5. признаки для ML-модели.

Вариант 2. Подбор пароля

В течение 15 минут в журнале аутентификации зафиксировано 400 неудачных попыток входа для разных пользователей. Источник — один внешний IP-адрес. Через 2 минуты после серии ошибок зафиксирован успешный вход.

Вариант 3. SQL-инъекция

В логах веб-сервера обнаружены запросы:

/login?id=1' OR '1'='1

/products?cat=2 UNION SELECT username,password FROM users

/search?q=test'; DROP TABLE orders;--

Вариант 4. DDoS-атака

В течение 5 минут количество HTTP-запросов к сайту выросло с 200 запросов в минуту до 50 000 запросов в минуту. Большая часть запросов приходит с разных IP-адресов.

Вариант 5. Malware beaconing

Рабочая станция каждые 120 секунд обращается к домену update-check-service.example и передает небольшие объемы данных. Пользователь в это время не работает.

Вариант 6. Lateral movement

После успешного входа пользователя ivanov с нового IP-адреса его рабочая станция начала подключаться к нескольким серверам по SMB, RDP и WinRM.

Вариант 7. Data exfiltration

С файлового сервера ночью был создан архив объемом 8 ГБ, после чего зафиксирована передача данных на неизвестный внешний IP-адрес.

Вариант 8. Privilege escalation

Учетная запись обычного пользователя была добавлена в группу администраторов домена. Перед этим в логах были зафиксированы неудачные попытки доступа к административной панели.

Вариант 9. XSS-атака

В логах веб-приложения обнаружены параметры запросов:

```
<script>alert('test')</script>  
<img src=x onerror=alert(1)>  
javascript:document.cookie
```

Вариант 10. Botnet-активность

Несколько рабочих станций внутри сети одновременно начали обращаться к одному внешнему IP-адресу через нестандартный порт 4444.

9. Требования к отчету

Отчет по практическому занятию должен содержать:

1. Титульный лист.
2. Тему и цель работы.
3. Номер индивидуального варианта.
4. Краткое описание анализируемой ситуации.
5. Таблицу классификации события.
6. Таблицу признаков атаки.
7. Таблицу источников данных.
8. Сформулированное правило обнаружения.
9. Таблицу признаков для ML-модели.
10. Вывод по работе.

10. Шаблон отчета

10.1. Описание ситуации

Параметр	Значение
Номер варианта	
Описание события	
Предполагаемая атака	
Объект атаки	
Источник атаки	
Потенциальные последствия	

10.2. Анализ признаков

Группа признаков	Описание
Сетевые признаки	
Признаки в логах	
Поведенческие признаки	
Временные признаки	
Дополнительные признаки	

10.3. Источники данных

Источник данных	Какие сведения дает	Зачем нужен
Firewall logs		
NetFlow		
Web logs		
Authentication logs		
DNS logs		
SIEM		

10.4. Правило обнаружения

Если _____,
и _____,
то сформировать событие _____
с уровнем критичности _____.

10.5. Признаки для ML-модели

Признак	Тип	Описание	Ожидаемое поведение при атаке
	числовой / категориальный / временной		
	числовой / категориальный / временной		
	числовой / категориальный / временной		

10.6. Итоговый вывод

В выводе необходимо ответить на вопросы:

1. Какой тип атаки наиболее вероятен?
2. Какие признаки подтверждают этот вывод?
3. Какие источники данных наиболее полезны?
4. Какое правило обнаружения можно применить?
5. Какие признаки можно использовать в ML-модели?
6. Какие меры реагирования целесообразны?

11. Контрольные вопросы

1. Что такое сетевая атака?
2. Зачем нужна классификация сетевых атак?
3. Чем port scanning отличается от brute force?
4. Какие признаки характерны для DDoS-атаки?
5. Какие признаки характерны для SQL injection?
6. Какие признаки характерны для XSS?
7. Что такое malware beaconing?
8. Какие признаки указывают на lateral movement?

9. Что такое data exfiltration?
10. Какие источники данных используются для обнаружения атак?
11. Чем сетевые признаки отличаются от признаков в логах?
12. Что такое поведенческий признак атаки?
13. Как признаки атак используются в машинном обучении?
14. Почему одно событие не всегда является доказательством атаки?
15. Почему важно учитывать временной интервал при обнаружении атак?